MCP Sentinel (VeriAuth-ZTA)

Continuous Zero-Trust Authorization Policy Engine & Runtime Security Sidecar for AI Agents

Hackurity 2026 • Track A: AI + Security Crossover • NIST SP 800-207 Architecture • AWS Cedar v3.2/v4.12 Engine • Obsidian Flow Design

---

1. Executive Summary & The Problem Solved

Modern enterprise AI deployments face a severe vulnerability: **standing privileges and one-time authentication**. When autonomous agents operate tools via the Model Context Protocol (MCP), they frequently hold long-lived ambient credentials. When an agent encounters an **Indirect Prompt Injection** within customer data, support tickets, or invoices, the agent falls victim to the **Confused Deputy Problem**, executing unauthorized transactions using its standing permissions.

MCP Sentinel introduces independent runtime verification between AI agents and the tools they propose to invoke. Governed by the principle: *'Let AI propose actions. Let security controls determine what is allowed.'* MCP Sentinel intercepts every JSON-RPC tool dispatch, verifies ephemeral Ed25519 workload identity claims, evaluates formal AWS Cedar policies, enforces dual-custody human-in-the-loop (HITL) step-up gates, and writes every outcome to an immutable SHA-256 Merkle audit chain.

> ***Zero-Trust Pipeline:***
> *[Untrusted Context / Attacker] → [Gemini 2.5 Flash Agent] → [MCP Sentinel Security Proxy (Non-Bypassable PEP Gate)] → [AWS Cedar PDP AST & Risk Scorer] → [Single-Use HMAC Nonce Ticket] → [Protected MCP Core / Financial Ledger] → [SHA-256 Audit Chain]*

2. Unified Product Experiences & Route Hierarchy

The project delivers a cohesive, end-to-end product architecture uniting the public marketing identity with the operational security console:

Route	Product View	Experience Context & Verified Capabilities
/	**Public Landing Page**	Obsidian Flow design system, liquid-glass sculptural shield, interactive 10-node software architecture explorer, red-team attack previews, and direct CTA to console.
/console	**Security Overview**	Executive telemetry dashboard: real-time authorization throughput, enforcement ratio (94.2%), P50/P95/P99 latency ticker, and Merkle chain height.
/accounts	**Account & Ledger**	Simulated core banking: dual account switcher (ACC-1001 vs ACC-1002), Titanium debit card freeze toggle, transaction search, and dispute modal.
/finance	**Gemini Finance Bot**	Conversational AI assistant: quick prompts, tool-call accordions, Cedar verdict badges, and dual-custody refund validation.
/graph	**Authorization Graph**	Interactive SVG Bezier topology with 4 simulation modes (normal, attack, quarantine, approval) and component inspector drawer.
/monitor	**Live Telemetry SOC**	Real-time event stream with decision filters (ALLOW, DENY, APPROVAL_REQUIRED), tool filters, and raw JSON modal inspector.
/incidents	**Incident Explorer**	Correlated multi-stage attack timeline, autonomous circuit breaker quarantine alert, and one-click quarantine reset control.
/policies	**Cedar Policy Studio**	Formal AWS Cedar policy IDE: static AST validator, live deployment, and Cedar Copilot (natural language to formal Cedar specification).
/identity	**Agent Identity Matrix**	SPIFFE-like URIs, Ed25519 scoped capability tokens, attenuated delegation chains (parent -> child), and real-time token revocation.
/attack-lab	**Attack Simulation Lab**	8 reproducible red-team scenarios with inline dual-custody HITL step-up approval gates and circuit breaker quarantine triggers.
/audit	**Cryptographic Audit**	SHA-256 forward-linked chain, live mathematical verification, and downloadable SOC 2 / NIST AI RMF executive compliance markdown.

3. Core Innovations & Zero-Trust Capabilities

• **AWS Cedar Automated Reasoning:** Evaluates access control requests under strict Default-Deny semantics. Forbid rules categorically supersede permits.
• **Multi-Factor Blast Radius Engine:** Formally calculates risk scores: Risk = min(100, Base + RoleDelta + InjectionDelta + DestructiveDelta + Velocity + Spend).
• **Single-Use Cryptographic Nonces:** Downstream tool code cannot execute without an unexpired, HMAC-SHA256 signed ticket tied to exact canonical arguments.
• **Autonomous Circuit Breaker:** Detects rapid violation velocity (3 repeated breaches within 60s) and automatically trips into QUARANTINE mode, revoking all active agent tokens.
• **Dual-Layer Architecture:** Live FastAPI backend + WebSockets paired with a resilient, offline-capable in-memory mock store for zero-downtime evaluation.

4. Winning 3-Minute Hackathon Demo Script for Evaluators

Minute 1 — Public Landing Page & Architecture (http://localhost:5173):
Show the Obsidian Flow landing page. Point to the interactive 10-node architecture diagram: *'Evaluators, 88% of teams report AI security incidents because agents authenticate once and retain standing credentials. MCP Sentinel interposes independent verification between the agent and tools.'* Click **'Enter Security Console →'**.

Minute 2 — Gemini Finance Assistant & Cedar Copilot:
1. **AI Finance Bot (/finance):** Show the conversational assistant proposing refunds and balances. Notice tool-call inspection accordions and Cedar decision badges.
2. **Policy Studio (/policies):** Open Cedar Copilot. Type: *'Allow financial remediation agent to issue refunds up to $75 only on active accounts'* → click **'Synthesize Cedar'** → instant formal Cedar AST generation!

Minute 3 — Red-Team Attack Lab & Cryptographic Proof:
1. **Attack Lab (/attack-lab):** Run Scenario 2 (*HITL Step-Up Gate*, $120 refund > $50 threshold). Show the pending approval gate pop up. Click **'Approve & Execute'** to demonstrate dual-custody authorization.
2. **Audit Explorer (/audit):** Click **'Verify Cryptographic Integrity'**. Show the green attestation badge confirming 100% of SHA-256 blocks validated without tampering. Click **'Compliance Attestation'** to preview SOC 2 & NIST AI RMF audit report.